

SOCIII Business Associate Agreement

HIPAA-Compliant · sociii.ai · Effective August 28, 2026

1. Parties and Definitions

This Business Associate Agreement is entered into between SOCIII, Inc. ("Business Associate" or "SOCIII") and the signing party ("Covered Entity" or "you"). For purposes of this BAA:

- "Covered Entity" has the meaning given in 45 CFR § 160.103 and includes HIPAA-covered healthcare providers, health plans, and healthcare clearinghouses, as well as creators and subscribers who qualify as covered entities or their business associates.
- "Business Associate" means SOCIII, acting in its capacity as a business associate that creates, receives, maintains, or transmits PHI on behalf of a Covered Entity.
- "Protected Health Information" (PHI) has the meaning given in 45 CFR § 160.103, including all individually identifiable health information transmitted or maintained by SOCIII on behalf of the Covered Entity.
- "Electronic Protected Health Information" (ePHI) means PHI that is created, received, maintained, or transmitted in electronic form.
- "Required by Law" has the meaning given in 45 CFR § 164.103. "Breach" has the meaning given in 45 CFR § 164.402. "Security Incident" has the meaning given in 45 CFR § 164.304.

2. Obligations of SOCIII as Business Associate

2.1 Permitted Uses and Disclosures

SOCIII may use and disclose PHI only to the extent necessary to:

- Perform the AI Digital Worker services described in the applicable worker subscription
- Perform data aggregation services relating to the healthcare operations of the Covered Entity
- Provide data security, management, and reporting services necessary to operate the Platform
- Carry out SOCIII's own legal responsibilities, as permitted by HIPAA

SOCIII will not use or disclose PHI in a manner that would violate HIPAA if done by the Covered Entity.

2.2 Safeguards

SOCIII will implement administrative, physical, and technical safeguards that:

- Prevent unauthorized use or disclosure of PHI beyond what is permitted by this BAA
- Comply with the HIPAA Security Rule (45 CFR Part 164, Subpart C) with respect to ePHI
- Include encryption of ePHI at rest (AES-256) and in transit (TLS 1.2+)
- Include role-based access controls, audit logging, and activity monitoring
- Include an immutable, append-only audit trail of all PHI access events

2.3 Subcontractors

SOCIII will obtain satisfactory assurances from any subcontractor that creates, receives, maintains, or transmits PHI on SOCIII's behalf, ensuring equivalent protections via a written BAA. Current subcontractors processing PHI include Google LLC (Firebase/GCP), Anthropic, PBC, and OpenAI, L.L.C. (AI inference). SOCIII maintains BAAs with these subcontractors.

2.4 Reporting

SOCIII will:

- Report to the Covered Entity any use or disclosure of PHI not provided for by this BAA within 10 business days of becoming aware
- Report any Breach of Unsecured PHI as required by 45 CFR § 164.410 within 60 calendar days of discovery (SOCIII applies a 10-business-day internal standard as a baseline)
- Report any Security Incident of which it becomes aware, including attempted unauthorized access

2.5 Access and Accounting

SOCIII will provide:

- Access to PHI in a Designated Record Set to the Covered Entity within 30 days of request
- An accounting of disclosures of PHI as required by 45 CFR § 164.528 within 60 days
- Amendment to PHI in a Designated Record Set as directed by the Covered Entity

2.6 HHS Access

SOCIII will make its internal practices, books, and records relating to the use and disclosure of PHI available to the Secretary of the Department of Health and Human Services for compliance purposes, as required by 45 CFR § 164.504(e)(2)(ii)(I).

2.7 HITECH Compliance

SOCIII complies with the privacy and security requirements of HITECH (42 U.S.C. § 17931 et seq.) and its implementing regulations, including notification of breaches to individuals, the Secretary, and (where applicable) the media; restrictions on the sale of PHI; and application of the minimum necessary standard to PHI uses.

3. Obligations of the Covered Entity

The Covered Entity will:

- Provide SOCIII with a copy of its Notice of Privacy Practices and any changes thereto that may affect SOCIII's use or disclosure of PHI
- Notify SOCIII of any restriction on use or disclosure of PHI to which it has agreed per 45 CFR § 164.522
- Not request SOCIII to use or disclose PHI in a manner that would violate HIPAA if done by the Covered Entity
- Obtain any consent or authorization required by HIPAA before disclosing PHI to SOCIII

4. Term and Termination

4.1 Term

This BAA is effective on the date of electronic execution and continues until the worker subscription it governs is terminated or until terminated earlier as provided herein.

4.2 Termination for Cause

Either party may terminate this BAA immediately upon written notice if the other party has materially breached a provision of this BAA and failed to cure such breach within 30 days of written notice.

4.3 Effect of Termination — Return or Destruction of PHI

Upon termination, SOCIII will, at the Covered Entity's option: return all PHI to the Covered Entity in a mutually agreed format within 30 days, or destroy all PHI that SOCIII maintains and provide written certification of destruction. If return or destruction is infeasible, SOCIII will extend the protections of this BAA to the PHI and limit further use to those purposes that make return or destruction infeasible. Minimum required retention periods under applicable law are exempt from destruction requirements.

5. Miscellaneous

5.1 Governing Law

This BAA is governed by HIPAA, HITECH, and implementing regulations, as interpreted by the HHS Office for Civil Rights (OCR). To the extent state law provides greater privacy protections, those state laws apply.

5.2 Regulatory References

All references to federal regulations refer to the current version as amended. If HIPAA, HITECH, or implementing regulations are amended, this BAA is deemed amended to comply with such changes automatically.

5.3 No Third-Party Beneficiaries

This BAA is for the exclusive benefit of the parties and their successors and permitted assigns. Nothing herein creates any third-party beneficiary rights.

5.4 Electronic Execution

This BAA is executed electronically via Dropbox Sign. Electronic signatures have the same legal effect as handwritten signatures under the Electronic Signatures in Global and National Commerce Act (E-SIGN Act, 15 U.S.C. § 7001) and applicable state laws (UETA). A signed PDF is stored in Firebase Storage and constitutes the original executed agreement.

5.5 Entire Agreement

This BAA constitutes the entire agreement between the parties with respect to the subject matter hereof and supersedes all prior oral or written agreements relating to HIPAA/PHI compliance in connection with the Platform.

6. Execution

By executing this BAA electronically, you represent that you have the authority to enter this agreement on behalf of the Covered Entity and that you have read and understood its terms.

Contact: legal@sociii.ai · SOCIII, Inc., 131 Continental Dr, Suite 305, Newark, DE 19713